

Security Rules Work: A Multi-Model Study of LLM Coding Agent Guardrails

SOUPS 2026
Poster Draft

Adhithya Rajasekaran · Axonome · adhithya@axonome.xyz · ORCID 0009-0004-1682-7958

Why This Study Exists

In CodeCoach, scanner findings were converted into persistent coding-agent rules. One pilot case looked paradoxical: a prohibition against an unsafe pattern made one model produce that pattern more often.

Pilot signal

A narrow “do not do X” failure motivated the larger study.

Replication question

Does rule wording generalize across models and CWEs?

Experiment

2,160

valid model trials

6

frontier coding models

6

security prompts

3

conditions per prompt

- **Control:** no rule injected.
- **Negative:** prohibition-framed rule.
- **Positive:** safe alternative-framed rule.

CodeCoach Pipeline

Scanner
Detects insecure code pattern.



Rule file
Writes persistent project guidance.

Coding agent
Reads rule before generation.



Detector
Checks generated code for CWE pattern.

Main Result

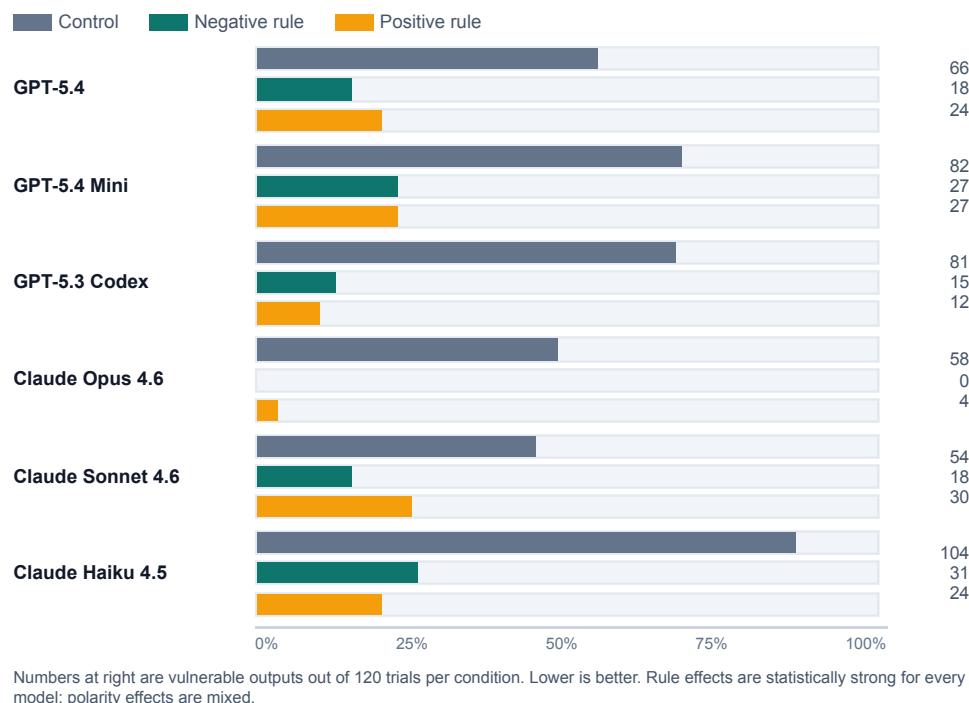
Rules reduce vulnerable code on every model.

The reliable effect is the presence of a targeted rule. The polarity of that rule is not consistently predictive.

6/6

models improved with rules

Vulnerability rate by model and condition



Numbers at right are vulnerable outputs out of 120 trials per condition. Lower is better. Rule effects are statistically strong for every model; polarity effects are mixed.

Polarity Is Not Stable

Positive wording was not a universal safety improvement. Sometimes it helped, sometimes it tied, and sometimes it was worse.

Model	Positive vs negative	Interpretation
GPT-5.4	+5.0 pp	positive worse
GPT-5.4 Mini	0.0 pp	tie
GPT-5.3 Codex	-2.5 pp	positive better
Claude Opus 4.6	+3.3 pp	positive worse
Claude Sonnet 4.6	+10.0 pp	positive worse
Claude Haiku 4.5	-5.8 pp	positive better

Interpretation

The pilot was real but narrow.

A single paradoxical case motivated the study; the larger replication shows it is not the general rule.

Persistent rules are useful guardrails.

Across GPT and Claude stacks, targeted security rules lowered vulnerable outputs.

Wording is model- and prompt-dependent.

Teams should evaluate rule files against their own prompts, not rely on a universal phrasing heuristic.

For Practitioners

- Keep rule files short, targeted, and security-reviewed.
- Prefer measurable guardrail tests over prompt folklore.
- Treat AGENTS.md and CLAUDE.md as security-critical configuration.